



IT Applications:

Electronic media in business and commerce

Public certificates

Dariusz Caban
dariusz.caban@pwr.edu.pl





Certificate

- How to prevent spoofing with the public key?
- A simple solution
 - A trusted third-party (Certificate Authority CA institution) vouches for the identity of the owner of the public key
 - CA does so by issuing an electronic document which
 - Identifies the owner of the certificate
 - Includes the public key of the owner
 - Specifies when the certificate expires (cannot be used any longer)
 - Specifies the legal applications of a certificate
 - CA signs the certificate using its private key, thus vouching for its authenticity
 - CA includes its certificate to prevent CA spoofing
- CA certificate chain
 - Root CA has a self-signed certificate
 - Self-signed certificate does not prevent spoofing





Certificate fields

- Certificate consists of
 - Named fields
 - Field values are text, numbers, bitstrings, ...
 - Standards require specific fields
- Certificate owner and public key
- Period of validity
 - From - until
- Purpose of the certificate
 - To identify a server
 - To identify a user
 - To sign other certificates
- Unique serial number





Revocation of certificates

- Certificate expires when its validity period is exceeded
- CA can revoke a certificate
 - CRL (certificate revocation list) contains the list of all revoked certificates of the issuer
 - CRL's are signed by the CA and publicized
 - CRL's are held locally and should be regularly updated
 - OCSP (online certificate status protocol)
 - RFC 2560
 - Used to verify certificates validity online





Certificate types

- Three main usages of certificates
 - CA institution certificate
 - Certified by a public entity
 - Self-signed certificate
 - Server certificate
 - Client software uses it to verify the identity of the server
 - User certificate
 - User can identify himself by distributing his certificate
 - Used in message exchange (for enveloping or signing)
 - Used in authentication/authorization





Certificate development

- Certificate request, includes name and generated public key
 - Name must be in a standardized format
 - Use of Distinguished Name (DN) correlated to directory services X.500
 - Contains a hierarchy of fields
 - Common Name (CN) is the leaf field
- Key generation
 - Public key to be included in the certificate
 - Private key kept in a separate encrypted file (key file)
- CA signs the certificate request using its private key





Policy of trust

- Value of a certificate depends on:
 - The trustworthiness of the signing institution (CA)
 - How did the CA institution verify the identity of the certificate owner?
- Certification Practice Statement
 - A public declaration by the CA on:
 - Procedures used to verify the identity of the certificate owner
 - Procedures used to protect confidential data
 - Protection against certificate forgery
 - Distribution of certificate revocation lists
 - Requirements placed on subordinate CAs
 - Usually available on the Web
 - A link may be included within the certificate





Building of trust

- Hierarchical model (PEM)
 - Central certificate authority IPRA
 - CA authorities representing major levels of trust (PCA)
 - CA institutions issuing certificates of this level of trust (CA)
- Public model (PKIX)
 - Certificates include legal usage and CPS
 - Every institution may create Root CA certificate (self signed)
 - Lists of trusted Root CAs are installed in user software
- Distributed model (OpenPGP)
 - Everybody trusts his own certificates
 - Everybody may add his signature to a certificate that he trusts (expressing the level of trust)
 - Personal/accumulated chains of trust
 - Key signing parties



Standardization of cryptographic data formats

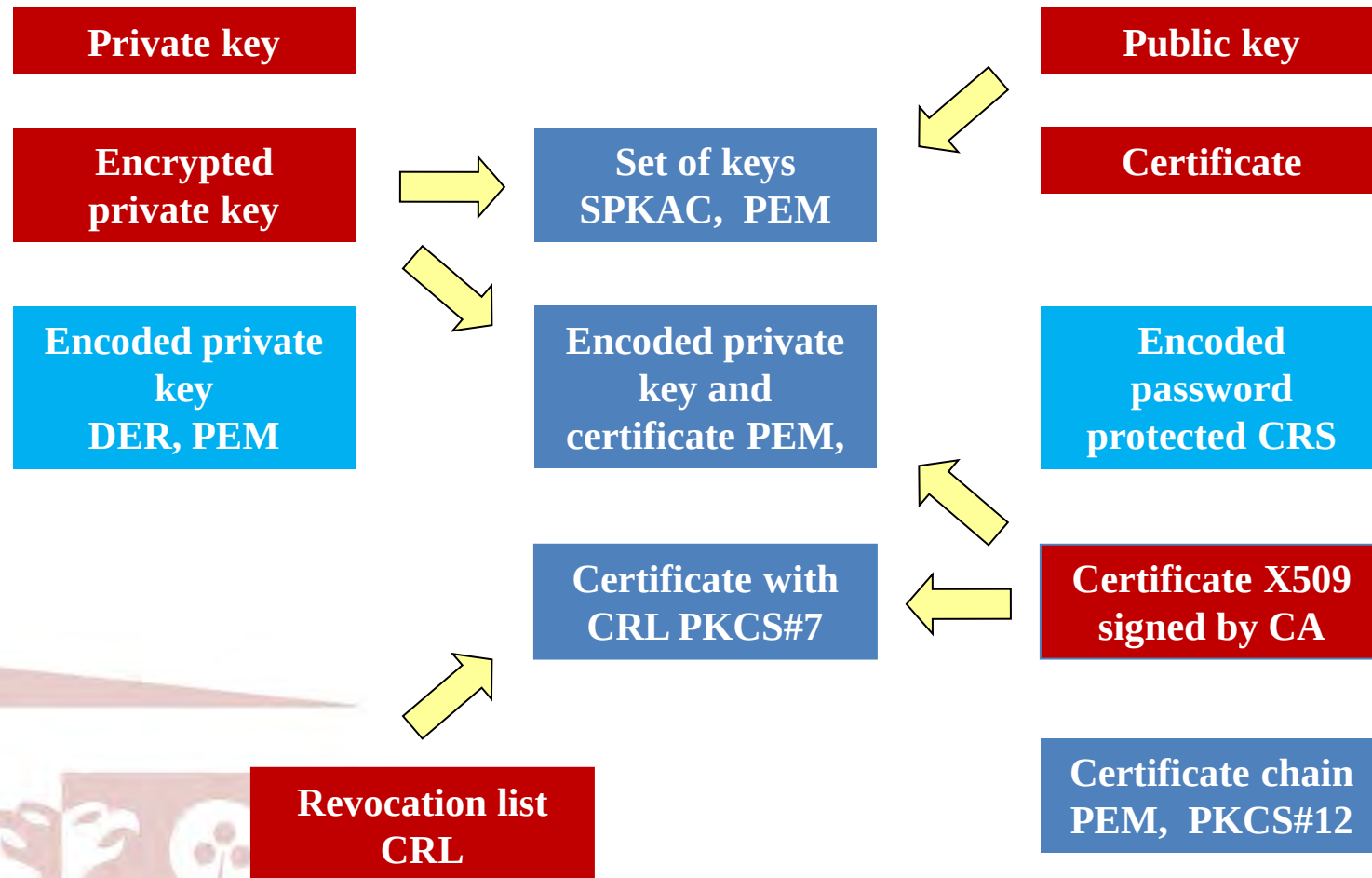


- Standard formats apply to:
 - Certificate request
 - Private key
 - Certificate
- Various sources of standarization
 - Recommendations of CCITT/OSI, currently called ISO/IEC
 - X509
 - Formats introduced by RSA Laboratories
 - PKCS#1 – PKCS#12
 - Working group PKIX within IETF framework
 - RFC and Internet-Drafts
 - Software providers
 - Netscape SPKAC
 - Microsoft





Public data formats





Public X509 certificate

- CCITT (ISO/IET/ITU)
 - 1988 version 1 of certificate – document X.509
 - Part of mail document X.400 and addressing document X.500
 - Encoding using ANS.1 and DER
 - Current version 3 released in 1996
- Privacy Enhanced Mail (PEM), how to use in Internet
 - Documents RFC 1421 – RFC 1424
 - Hierarchical trust model
 - PEM encoding – DER mime-encoded using base64 and separators
- NRSA Laboratories PKCS#1 – PKCS#12
 - Documentation of ANS.1/DER encoding for use in cryptographic formats
 - Packaging of certificates, CRL lists and keys
- Working group PKIX - RFC 2459
 - X509 certificate and field extensions for Internet use





RFC 2459/5280 with updates

- Must be represented using ANS.1 with DER encoding
 - Main fields
 - Certificate TBS (to be signed)
 - Cipher suite used for signing the certificate
MD2/RSA MD5/RSA SHA-1/RSA **SHA-1/DSA**
 - Signature (bit stream)
 - Certificate TBS
 - Version v1(0), v3(2)
 - Serial number
 - Cipher suite used for signing the certificate (same as above!)
 - DN name of certificate issuer
 - Validity period
 - DN name of certificate owner
 - **Public key**
 - Extensions





RFC 5280 - certificate

- Distinguished Name
 - If X.500 is available this should be the DN in the service
 - Fields
 - Country C=PL
 - Organization O=Wrocław University of Technology
 - Unit OU=Institute Computer Engineering Control and Robotics
 - Common Name CN=Darek Caban
 - In server certificates this should be the server domain name
 - Optional fields such as city, postal code (not email!)
 - DN must be unique
 - Compared as an entity (must have exactly the same fields)
- Public key
 - Cipher suite identifier RSA, Diffie-Hellman, DSA
 - Key value





RFC 5280 - certificate

- Extensions
 - Authority/Subject Key Identifier
 - Identification of multiple keys of the same owner
 - Key Usage, Extended Key Usage
 - Permissible usages of the certificate
 - Certificate Policies
 - CPS address and/or textual description
 - Identifier
 - Subject Alternative Name
 - Owner domain address, http or email
 - Name Constraints
 - Limitations on DN branches that can be certified
 - CRL Distribution Points

